Sky: Spark Saving Intents

Security Review

Cantina Managed review by:
M4rio.eth, Lead Security Researcher
Xmxanuel, Lead Security Researcher

March 11, 2026

Contents

1 Introduction **2**
1.1 About Cantina . . . 2
1.2 Disclaimer . . . 2
1.3 Risk assessment . . . 2
1.3.1 Severity Classification . . . 2

2 Security Review Summary **3**

3 Findings **4**
3.1 Low Risk . . . 4
3.1.1 De-whitelisted vaults can still be fulfilled for existing pending requests . . . 4
3.2 Informational . . . 4
3.2.1 Batch fulfill griefing via `approval` frontrunning . . . 4
3.2.2 Request updates reset queue priority and no partial fill increases user execution delay 4

1 Introduction

1.1 About Cantina

Cantina is a security services marketplace that connects top security researchers and solutions with clients. Learn more at cantina.xyz

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity level	**Impact: High**	**Impact: Medium**	**Impact: Low**
Likelihood: high	Critical	High	Medium
Likelihood: medium	High	Medium	Low
Likelihood: low	Medium	Low	Low

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings are a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

2 Security Review Summary

Sky Protocol is a decentralised protocol developed around the USDS stablecoin.

From Mar 2nd to Mar 10th the Cantina team conducted a review of spark-savings-intents on commit hash 2525ad01 (tag v1.0.0-beta.0). The team identified a total of **3** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	1	0	1
Gas Optimizations	0	0	0
Informational	2	1	1
Total	**3**	**1**	**2**

The Cantina Managed team reviewed Sky's spark-savings-intents holistically on commit hash d9045fca (tag v1.0.0) and concluded that all findings were addressed and no new vulnerabilities were identified.

3 Findings

3.1 Low Risk

3.1.1 De-whitelisted vaults can still be fulfilled for existing pending requests

Severity: Low Risk

Context: src/SavingsVaultIntents.sol#L89, src/SavingsVaultIntents.sol#L141-L165

Description: Vault whitelist is enforced in `request`, but not in `fulfill`. This means governance can de-whitelist a vault, yet already-pending requests for that vault can still be fulfilled by relayer. In practice, de-whitelisting is usually done because the vault is considered risky, so continuing automated fulfill for old requests can conflict with the expected emergency.

Recommendation: Check vault whitelist again inside `fulfill`. If vault is de-whitelisted, block relayer execution which will force the users to withdraw manually from the vault. This aligns behavior with why governance would de-whitelist in the first place.

Sky: Acknowledged. In practice if a vault needed to be removed for some reason we would just stop fulfilling requests in the planner.

Cantina Managed: Acknowledged.

3.2 Informational

3.2.1 Batch fulfill griefing via `approval` frontrunning

Severity: Informational

Context: SavingsVaultIntents.sol#L165

Description: When the `relayer` batches multiple `fulfill()` calls in a single transaction (like via a Safe), a user included in the batch can front-run it by reducing their share approval to the contract. This causes `vault.redeem` to revert due to insufficient allowance, reverting the entire batch and griefing all other users.

Recommendation: The off-chain planner should be able to handle such scenarios and re-execute the batch excluding the user. An alternative would be to not revert the entire batch if one fulfill fails.

Sky: Acknowledged.

Cantina Managed: Acknowledged.

3.2.2 Request updates reset queue priority and no partial fill increases user execution delay

Severity: Informational

Context: src/SavingsVaultIntents.sol#L119-L126, src/SavingsVaultIntents.sol#L165, README.md#L155-L168

Description: When a user changes request parameters (amount, receiver, deadline), they must create a new request. This increments `requestId` and overwrites the previous request in storage. If relayer processing is FIFO by request id, this effectively pushes the user to the back of the queue.

Also, `fulfill` always redeems the full stored `shares` (`redeem(request_.shares, ...)`), so there is no partial-fill path. A user cannot keep their queue position and reduce size for faster execution.

Recommendation: Consider documenting this behavior better so that the user will be aware of this before doing any update to their requests.

Sky: Documented in PR 8.

Cantina Managed: Fix verified.